DOC-006 — Requisitos Não Funcionais, Segurança e Diretrizes Técnicas

Plataforma SaaS para Gestão de Oficinas Mecânicas

Versão: 0.1 — Consolidação para validação

Data: 7 de outubro de 2026

Status: Proposta para validação

Documentos relacionados: DOC-001 a DOC-005, DOC-007 e DOC-008.

Controle documental: Documento reconstituído a partir do registro disponível. Não reproduz integralmente os identificadores da primeira versão.

1. Objetivo

Estabelecer requisitos de qualidade, segurança, integridade e operação, sem obrigar tecnologia específica.

2. Premissas técnicas

• Aplicação Web.

• Ambiente e banco compartilhados.

• Isolamento lógico multi-tenant.

• Uma unidade ativa por empresa no MVP.

• Operação online.

• Interface em português do Brasil.

• Valores em reais.

• Sem operação offline prevista.

3. Arquitetura e isolamento

O contexto empresarial deve ser validado no servidor.

Proteção deve abranger:

• Consultas.

• Alterações.

• Relacionamentos.

• Relatórios.

• Exportações.

• Arquivos.

• Tarefas assíncronas.

• Integrações.

• Caches e estruturas derivadas.

Identificadores imprevisíveis não substituem autorização.

4. Identidade e sessões

• Autenticação confiável.

• Credenciais protegidas no componente de identidade.

• Sessões com expiração e revogação.

• Suspensão de vínculo refletida nas autorizações.

• Proteção contra tentativas abusivas.

• Controles adicionais proporcionais ao risco de operações sensíveis.

5. Privacidade

• Coleta limitada à finalidade.

• Inventário de dados pessoais.

• Inclusão de cópias históricas e anexos no inventário.

• Acesso por necessidade funcional.

• Retenção e descarte definidos.

• Tratamento de solicitações de titulares.

• Procedimento de resposta a incidentes.

• Logs sem dados pessoais desnecessários.

6. Integridade e concorrência

• Transações para efeitos relacionados.

• Controle de edição concorrente.

• Idempotência em confirmações críticas.

• Restrições estruturais quando adequadas.

• Reconciliação de saldos derivados.

• Correções rastreáveis.

• Prevenção de cobranças, consumos e recebimentos duplicados.

7. Anexos

• Armazenamento privado.

• Validação de tipo e tamanho.

• Verificação de segurança antes de disponibilização.

• Autorização associada ao registro de origem.

• Proteção contra exposição entre empresas.

• Política de retenção e eliminação.

• Registro do estado de verificação.

8. Desempenho

Metas de tempo de resposta devem considerar consultas, gravações, relatórios e operações críticas.

Os valores numéricos serão definidos a partir do perfil de carga esperado.

Testes devem representar volumes de empresas, usuários simultâneos, atendimentos, movimentos e anexos.

9. Disponibilidade e recuperação

• Monitoramento da aplicação e dependências.

• Backups protegidos.

• Testes de restauração.

• Procedimentos de recuperação.

• Plano de indisponibilidade.

• Separação entre ambientes.

• Definição de RPO e RTO.

Nenhuma meta numérica de disponibilidade, RPO ou RTO está aprovada nesta consolidação.

10. Observabilidade e auditoria

• Correlação de requisições.

• Registro de falhas e rejeições.

• Monitoramento de operações críticas.

• Restrição de acesso aos logs.

• Proteção contra alteração indevida.

• Exclusão de credenciais dos registros.

• Identificação de agentes automáticos e acessos excepcionais.

11. Usabilidade e acessibilidade

• Linguagem clara.

• Datas e horários no contexto operacional.

• Valores apresentados em reais.

• Mensagens de validação compreensíveis.

• Distinção entre rascunho e confirmação.

• Confirmação de ações críticas.

• Acessibilidade considerada na interface.

• Ausência de promessa de funcionamento offline.

12. Engenharia

• Versionamento de código e esquema.

• Migrações controladas.

• Testes automatizados.

• Revisão de segurança.

• Segredos fora do código.

• Implantação e reversão documentadas.

• Dados de teste sem exposição indevida de dados reais.

13. Condições de entrada em produção

1. Isolamento multi-tenant testado.

2. Permissões verificadas no servidor.

3. Fluxos críticos cobertos por testes.

4. Restauração de backup demonstrada.

5. Monitoramento disponível.

6. Resposta a incidentes definida.

7. Retenção e recuperação aprovadas.

8. Ausência de falhas críticas conhecidas nos fluxos essenciais.

14. Decisões pendentes

Arquitetura física, identidade, sessões, arquivos, privacidade, capacidade, metas de desempenho, disponibilidade, RPO, RTO, auditoria e operação.